CrowdStrike发现五种新型AI提示词注入攻击手法

至顶科技 2026-07-16

安全公司CrowdStrike近期识别出五种新型提示词注入技术，这些技术可能给企业带来严重安全风险。提示词注入攻击利用了AI在企业中日益广泛的应用，通过欺骗大语言模型来接受人类操作者本能识别为可疑的指令。

CrowdStrike将以下五种新型攻击方式纳入其提示词注入分类体系：

触发式规则植入：攻击者植入一条表面上看似无害的新规则，但该规则可在特定条件下被激活，进而导致模型出现异常行为。

认知Token压制：通过引导模型的语言选择偏离已有的拒绝模式，绕过模型内置的安全防护机制。

算法化载荷分解：将恶意指令分多个阶段传递，每个阶段单独来看均显得无害，但组合在一起后便可拼合成一条威胁性更强的完整指令。

特殊Token注入：类似于在正常指令中嵌入伪造"控制开关"，攻击者通过制造混乱，诱使模型将不可信的用户内容提升至高优先级系统指令的地位。

非知情用户上下文数据注入：利用受信数据与可执行指令之间的边界漏洞，诱骗用户将恶意指令作为上下文数据的一部分传递给大语言模型。提示词本身可能完全无害，恶意指令被隐藏在周围的上下文数据中。当用户上传文档、转发邮件或添加内容后，AI在处理这些内容时便会触发攻击。

CrowdStrike指出，安全团队可通过多种方式防范此类攻击，包括对所有模型上下文来源进行威胁建模、扩大测试覆盖范围，以及将检测工程延伸至针对组合型攻击的防御。

Q&A

Q1：提示词注入攻击是什么？它是如何危害企业的？

A：提示词注入攻击是一种利用大语言模型处理指令方式的漏洞实施的安全攻击手段。攻击者通过构造特殊输入，欺骗大语言模型接受本不应执行的指令，从而绕过安全机制或执行恶意操作。随着AI在企业中的广泛应用，大语言模型接触的数据来源越来越多，攻击面也随之扩大，企业面临的风险日益增加。

Q2：CrowdStrike新发现的五种提示词注入攻击中，哪种最难被察觉？

A：非知情用户上下文数据注入相对最难被察觉，因为提示词本身可能完全无害，恶意指令被隐藏在用户上传的文档、转发的邮件或其他内容的上下文数据中。用户在毫不知情的情况下将恶意指令引入系统，待AI处理这些内容时攻击才会触发，极具隐蔽性。

Q3：企业如何防御提示词注入攻击？

A：CrowdStrike建议企业从以下几个方面入手：对所有模型上下文数据的来源进行系统性威胁建模，识别潜在风险点；扩大安全测试的覆盖范围，涵盖更多攻击场景；并将检测工程能力延伸至组合型攻击的识别与防御，以应对多阶段、分步骤的复杂攻击手法。